SBOM Standard and Tool Selection

Task B

William A. Davis
CS 690 Graduate Research Project, Fall 2026
Advisor: Dr. Omar Ochoa
October 05, 2026

Decision

The project uses CycloneDX JSON, specification version 1.5, as its SBOM format, and the parser accepts versions 1.4 through 1.6. SPDX support is deferred, as the proposal allows. The SBOMs used for evaluation are generated with the CycloneDX project's own generator for each package ecosystem, because those generators record the full dependency graph. Syft remains in the toolset for quick inventories and as a fallback. The pipeline itself is written in Python 3.11 or later using only the standard library, with pytest for testing. Vulnerability data for Task G will come from the OSV API, the NVD API v2, the FIRST EPSS API and the CISA KEV catalog.

Why Syft Alone Was Not Enough

The proposal named "Syft or CycloneDX CLI" as the generation tools. Before committing to Syft, I ran Syft 1.18.1 against the source trees of all four test projects and compared its output with the ecosystem-specific CycloneDX generators.

Project	Syft components	Syft dependency links	Generator components	Generator dependency links
Juice Shop (npm)	52 (GitHub Actions only, because the repository has no lockfile)	0	689	1,063
PyGoat (Python)	36	0	33	41
WebGoat (Maven)	64	46	191	380
Gitea (Go)	1,400 (Go, frontend npm and tooling combined)	20	231	733

Syft is good at finding packages, but when it scans source directories it records almost none of the parent and child relationships between them. Without those relationships there is no dependency depth, and depth is one of the five scoring factors. The CycloneDX generators resolve the full graph. CycloneDX CLI, the other tool named in the proposal, does not generate SBOMs at all; it converts, merges and validates them, so it has no role in generation.

Generators Used

Ecosystem	Tool and version	Notes
npm	cyclonedx-npm 2.1.0	Run on a lockfile generated with `npm install --package-lock-only`; development dependencies omitted
Python	cyclonedx-bom 5.1.1 (environment mode)	Run on a virtual environment with the pinned requirements installed, using Python 3.9 to match the project; the root component is added and optional-extra links are removed by a helper script
Maven	cyclonedx-maven-plugin 2.9.1	Test and provided scopes excluded
Go	cyclonedx-gomod 1.9.0 (application mode)	Only the modules linked into the gitea binary, not the whole module graph
Any	Syft 1.18.1	Inventory and container-image scanning, and a fallback when no generator fits

Every generation command is recorded, with pinned versions, in the script scripts/generate_sboms.sh.

Effect on the Proposal

The next revision of the planning package should replace "Syft or CycloneDX CLI depending on project type" with "CycloneDX ecosystem generators, with Syft for inventory." Because the pipeline only requires a CycloneDX document that has a root component and a dependencies section, it remains independent of any one ecosystem.